

PCAP Analysis Report – Traffic.pcapng

Executive Summary

The packet capture contains **2,630 packets** and shows network communication between an internal host (10.173.142.85) and multiple external servers, including Google infrastructure and the intentionally vulnerable web application **Acunetix test site** testasp.vulnweb.com.

The most significant finding is the presence of **sensitive user information transmitted over unencrypted HTTP**, including:

- Username
- Full name
- Email address
- Password

Because the traffic was sent via **plain HTTP**, anyone with access to the network path could intercept and read these credentials.

1. Capture Overview

Metric	Value
File Type	PCAPNG
Total Packets	~2,630
Main Internal Host	10.173.142.85
Protocols Observed	TCP, HTTP, HTTPS, DNS
External Services	Google services, testasp.vulnweb.com
Sensitive Data Found	Yes

2. Top Communicating Hosts

IP Address	Observations
10.173.142.85	Primary client workstation
142.251.150.119	Google infrastructure
172.217.174.74	Google infrastructure
142.250.143.141	Google infrastructure
44.238.29.244	HTTP communication
testasp.vulnweb.com	Vulnerable web application

Observation

Most traffic is encrypted HTTPS communication with Google services, which is normal and generally secure.

However, communication with **testasp.vulnweb.com** occurred over **HTTP**, exposing transmitted information.

3. HTTP Traffic Analysis

The following HTTP requests were identified:

Method	Host	Resource
GET	google.com	/
GET	testasp.vulnweb.com	/Templatize.asp
GET	testasp.vulnweb.com	/styles.css
GET	testasp.vulnweb.com	/Register.asp
POST	testasp.vulnweb.com	/Register.asp
GET	testasp.vulnweb.com	/Login.asp
GET	testasp.vulnweb.com	/default.asp

Security Observation

The presence of a **POST request over HTTP** is particularly important because POST requests often carry user-submitted data.

4. Exposed Registration Data

A registration form submission was recovered from the capture.

Captured POST Data

tfUName=Jhon+Ripper

tfRName=Jhon+The+Ripper

tfEmail=Ripper@gmailcom

tfUPass=12345

Decoded Values

Field	Value
Username	Jhon Ripper
Real Name	Jhon The Ripper
Email	Ripper@gmailcom

Password	12345
-----------------	-------

5. Credential Exposure Finding

Severity: HIGH

The packet capture contains credentials transmitted in plaintext.

Evidence

tfUPass=12345

Risk

An attacker monitoring the same network could obtain:

- Usernames
- Passwords
- Email addresses
- Session information

This could lead to:

- Account compromise
 - Credential reuse attacks
 - Unauthorized access
 - Identity theft
-

6. Personally Identifiable Information (PII)

The following personal information was visible in network traffic:

Data Type	Exposed
Username	Yes
Full Name	Yes
Email Address	Yes
Password	Yes

Impact

Exposure of PII may violate:

- Organizational security policies
 - Privacy requirements
 - Internal compliance standards
-

7. Session Information Exposure

The capture also contains HTTP cookies:

Cookie: ASPSESSIONIDCSCBDSDD=JMMCILKCFNIKFIJEJIGBJMEF

Risk

If the web application does not properly regenerate session IDs after authentication, attackers may attempt:

- Session hijacking
- Session fixation attacks
- User impersonation

8. Encryption Assessment

Traffic Type	Status
Google Communications	HTTPS (Encrypted)
VulnWeb Registration	HTTP (Unencrypted)

Observation

Most external traffic uses TLS encryption, but the registration process on testasp.vulnweb.com does not.

This means all submitted information can be viewed directly in packet captures.

9. Security Findings Summary

Finding	Severity
Plaintext password transmission	High
Exposed registration form data	High
PII disclosure	High
Session cookie exposure	Medium
Lack of HTTPS for registration page	High

10. Recommendations

Immediate Actions

1. Enforce HTTPS across all pages.
2. Disable plaintext HTTP access.
3. Enable HSTS (HTTP Strict Transport Security).
4. Encrypt all authentication traffic.
5. Use secure session cookies:
 - Secure flag
 - HttpOnly flag
 - SameSite flag

Credential Security

1. Never transmit passwords via HTTP.
2. Enforce strong password policies.
3. Implement MFA where possible.
4. Hash passwords using modern algorithms:
 - Argon2
 - bcrypt
 - scrypt

Monitoring

1. Monitor for plaintext credentials in network captures.
2. Deploy IDS/IPS signatures for credential leakage.
3. Regularly review packet captures for sensitive data exposure.

11. DNS Information Leakage

Even when HTTPS is used, DNS requests often reveal:

- Websites visited
- Internal naming conventions
- Third-party services used

Example findings:

Risk	Impact
DNS requests in plaintext	Browsing activity visible
Internal hostnames exposed	Network reconnaissance
External service discovery	Attack surface mapping

12. Cleartext HTTP Headers

HTTP requests often expose:

User-Agent:

Referer:

Cookie:

Host:

These can reveal:

- Browser version
- Operating system
- Previous pages visited
- Session identifiers

Example Risk

An outdated browser version in User-Agent may indicate vulnerable software.

13. Session Hijacking Possibility

You already found:

Cookie: ASPSESSIONID...

Further investigation should determine:

Check	Risk
Cookie transmitted over HTTP	High
Missing Secure flag	High
Missing HttpOnly flag	Medium
Session ID reused	High

If valid session cookies are captured, an attacker may impersonate users without knowing the password.

14. Weak Password Detection

You identified:

Password: 12345

This is noteworthy on its own.

Risk Level: Critical

Reasons:

- Common password
- Easily brute-forced
- Frequently found in leaked password databases

You can create a separate finding:

Finding	Severity
Weak Password Usage	Critical

15. User Enumeration

Look for:

Login failed

User exists

Username already taken

If different responses occur for valid and invalid users, attackers can enumerate accounts.

16. Application Fingerprinting

From the traffic:

ASPSESSIONID

Register.asp

Login.asp

You can infer:

Observation	Meaning
ASP pages	Microsoft ASP application
ASPSESSIONID	ASP session management
Legacy technology	Potentially outdated stack

Legacy web applications often contain:

- SQL Injection

- XSS
 - Session flaws
 - Weak authentication
-

17. Internal Host Profiling

The workstation:

10.173.142.85

can be profiled by:

- Operating system
- Browser version
- Applications used
- Update status

This is valuable for attackers performing reconnaissance.

18. Authentication Workflow Analysis

You observed:

Register.asp

Login.asp

default.asp

This suggests:

1. User visits registration page
2. Account created
3. User logs in
4. Redirect to authenticated page

A report can note:

The entire authentication lifecycle was observable through network traffic due to the absence of transport encryption.

This is a strong finding for management.

19. Data Exposure Classification

You can classify the leaked data formally.

Data Type	Classification
Username	Sensitive
Full Name	PII
Email Address	PII
Password	Confidential
Session Cookie	Authentication Secret

This looks more professional in security reports.

20. MITM Attack Feasibility

Since HTTP is used:

An attacker connected to the same:

- Wi-Fi network
- LAN segment
- Corporate switch (via ARP spoofing)

could potentially:

- Capture credentials
- Modify requests
- Inject malicious responses
- Hijack sessions

Risk Statement

The absence of TLS encryption makes the application susceptible to passive credential interception and active man-in-the-middle attacks.

Findings I'd Add to the Final Report

#	Finding	Severity
1	Credentials transmitted in plaintext	High
2	Personal information disclosure	High
3	Session cookie exposure	Medium
4	Weak password ("12345") observed	Critical
5	Authentication performed over HTTP	High
6	Potential session hijacking risk	High
7	Application technology fingerprinting possible	Medium
8	User activity and registration workflow visible	Medium
9	DNS and metadata leakage	Low
10	Susceptibility to MITM attacks	High